



SEGG-U1-P1 — OWASP Top 10: Investigación y análisis de vulnerabilidades

Alumna: Luz Celeste López Rivera
Docente: Gerardo Ramírez Villarreal

Tabla de las 10 vulnerabilidades

A01:2025 Broken Access Control	
Descripción	Esta vulnerabilidad ocurre cuando un sistema no controla correctamente lo que cada usuario puede hacer o ver dentro de la aplicación.
Ejemplo de ataque	Un atacante cambia el ID de una URL para entrar a la cuenta de otros usuarios o acceder a paginas de administrador sin permisos.
Impacto potencial	Puede provocar robo de información, modificación de datos importantes o accesos no autorizados a funciones del sistema.
Método de mitigación	Aplicar controles de acceso desde el servidor validar permisos de usuario y restringir accesos según sus roles.

A02:2025 Security Misconfiguration	
Descripción	Esta vulnerabilidad ocurre cuando un sistema o servidor esta mal configurado y deja abiertas opciones inseguras que pueden ser aprovechadas por atacantes.
Ejemplo de ataque	Un atacante encuentra una cuenta con contraseña por defecto o accede a directorios públicos que deberían estar protegidos.
Impacto potencial	Puede provocar robo de información, acceso no autorizado al sistema o exposición de datos sensibles.
Método de mitigación	Configurar correctamente servidores y aplicaciones, eliminar configuraciones innecesarias y mantener actualizaciones de seguridad contantes.

A03:2025 Software Supply Chain Failures	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación utiliza componentes, librerías o herramientas externas que tienen fallas de seguridad o han sido comprometidas.
Ejemplo de ataque	Un atacante modifica una librería popular y el sistema la instala sin detectar que contiene código malicioso.
Impacto potencial	Puede provocar robo de datos, ejecución de código malicioso o control parcial del sistema afectado.
Método de mitigación	Mantener actualizadas las dependencias, usar fuentes confiables y monitorear vulnerabilidades en componentes externos.

A04:2025 Cryptographic Failures	
Descripción	Esta vulnerabilidad ocurre cuando la información sensible no está protegida correctamente mediante cifrado o se utilizan métodos de seguridad débiles.
Ejemplo de ataque	Un atacante intercepta datos enviados por una página que no utiliza HTTPS o roba contraseñas almacenadas con cifrado inseguro.
Impacto potencial	Puede causar robo de contraseñas, filtración de datos personales o acceso no autorizado a cuentas.
Método de mitigación	Utilizar cifrado moderno, proteger datos sensibles y aplicar protocolos seguros como HTTPS y TLS.

A05:2025 Injection	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación permite que un atacante inserte comandos o código malicioso mediante datos que introduce el usuario.
Ejemplo de ataque	Un atacante escribe código SQL en un formulario para acceder a información de la base de datos sin autorización.
Impacto potencial	Puede provocar robo de información, modificación de datos o incluso control del sistema.
Método de mitigación	Validar correctamente los datos ingresados por el usuario y utilizar consultas parametrizadas para evitar inyecciones.

A06:2025 Insecure Design	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación tiene fallas desde su diseño o arquitectura, dejando espacios que pueden ser aprovechados por atacantes.
Ejemplo de ataque	Un sistema no limita correctamente las compras automáticas y bots pueden acaparar productos en segundos.
Impacto potencial	Puede causar abuso de funciones, pérdida de dinero, acceso indebido o problemas de seguridad difíciles de corregir.
Método de mitigación	Diseñar aplicaciones pensando en la seguridad desde el inicio, realizar modelado de amenazas y aplicar buenas prácticas de desarrollo seguro.

A07:2025 Authentication Failures	
Descripción	Esta vulnerabilidad ocurre cuando el sistema no protege correctamente el proceso de inicio de sesión o la identidad de los usuarios.
Ejemplo de ataque	Un atacante utiliza contraseñas robadas o débiles para entrar a cuentas sin autorización.
Impacto potencial	Puede provocar robo de cuentas, acceso no autorizado y filtración de información personal.
Método de mitigación	Utilizar contraseñas seguras, autenticación multifactor y limitar intentos fallidos de inicio de sesión.

A08:2025 Software or Data Integrity Failures	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación confía en software, actualizaciones o datos sin verificar si fueron modificados o provienen de una fuente confiable.
Ejemplo de ataque	Un atacante distribuye una actualización falsa con código malicioso y el sistema la instala sin validar su integridad.
Impacto potencial	Puede provocar ejecución de código malicioso, robo de información o compromiso total del sistema.
Método de mitigación	Verificar firmas digitales, usar fuentes confiables y proteger correctamente los procesos de actualización y despliegue.

A09:2025 Security Logging & Alerting Failures	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación no registra correctamente actividades sospechosas o no genera alertas ante posibles ataques.
Ejemplo de ataque	Un atacante entra al sistema varias veces y nadie detecta la actividad porque no existen registros o alertas adecuadas.
Impacto potencial	Puede provocar que ataques o filtraciones de datos pasen desapercibidos durante mucho tiempo.
Método de mitigación	Implementar registros de actividad, monitoreo constante y alertas automáticas ante comportamientos sospechosos.

A10:2025 Mishandling of Exceptional Conditions	
Descripción	Esta vulnerabilidad ocurre cuando una aplicación no maneja correctamente errores, excepciones o situaciones inesperadas dentro del sistema.
Ejemplo de ataque	Un atacante provoca errores repetidos hasta hacer que el sistema falle o revele información sensible en mensajes de error.
Impacto potencial	Puede causar caídas del sistema, filtración de información o comportamientos inesperados que afecten la seguridad.
Método de mitigación	Implementar manejo adecuado de errores, validación de entradas y registros seguros de eventos y excepciones.

Casos reales de cada vulnerabilidad

Vulnerabilidad	Empresa afectada	Año	Cómo fue explotada
A01: Broken Access Control	Facebook	2018	Un fallo en los tokens de acceso permitió que atacantes ingresaran a cuentas de usuarios sin autorización.
A01: Broken Access Control	SolarWinds Serv-U	2025	Una vulnerabilidad de control de acceso permitía crear cuentas de administrador y ejecutar código con privilegios elevados.
A02: Security Misconfiguration	Logstash	2015	El sistema no validaba correctamente certificados SSL/TLS, permitiendo ataques Man-in-the-Middle y robo de información.
A02: Security Misconfiguration	Elastic Cloud Enterprise	2017	El tráfico entre servicios no estaba cifrado adecuadamente, permitiendo interceptar datos sensibles.
A03: Software Supply Chain Failures	SolarWinds Help Desk	Web 2025	Una vulnerabilidad de deserialización insegura permitía ejecutar comandos remotos en el servidor sin autenticación.
A03: Software Supply Chain Failures	SolarWinds Help Desk	Web 2025	Un atacante podía aprovechar una falla de bypass de seguridad para acceder a funciones restringidas del sistema.
A04: Cryptographic Failures	UberEATS	2017	La aplicación utilizaba una clave de cifrado fija dentro del código, permitiendo que atacantes pudieran descifrar información almacenada.
A04: Cryptographic Failures	Disney Maleficent Fall	– Free 2014	La aplicación no verificaba correctamente certificados SSL, permitiendo que atacantes interceptaran información mediante conexiones falsas.
A05: Injection	Adobe Experience Manager	2024	Una vulnerabilidad XSS permitía insertar scripts maliciosos en formularios vulnerables y ejecutar código en el navegador de otros usuarios.

A05: Injection	LinkedIn Oncall	2021	Una vulnerabilidad XSS permitía insertar código malicioso en la barra de búsqueda y ejecutar scripts en el navegador de otros usuarios.
A06: Insecure Design	Tesla Model 3	2022	La autenticación mediante Phone Key podía ser engañada mediante ataques Man-in-the-Middle en la conexión Bluetooth.
A06: Insecure Design	LinkedIn Mobile	2025	La aplicación mostraba vistas previas confiables aunque el enlace real había sido cambiado por uno malicioso, facilitando ataques de phishing.
A07: Authentication Failures	Dropbox Android	2018	Una vulnerabilidad permitía evadir la autenticación usando un código de acceso arbitrario mediante manipulación de la aplicación.
A07: Authentication Failures	Dropbox iOS	2018	Fallas en la validación biométrica permitían autenticarse con huellas digitales no autorizadas.
A08: Software or Data Integrity Failures	LinkedIn Browser Toolbar	2008	La aplicación no verificaba correctamente la autenticidad de las actualizaciones, permitiendo ejecutar código malicioso mediante actualizaciones falsas.
A08: Software or Data Integrity Failures	Dropbox Desktop	2024	Una falla en carpetas compartidas permitía ejecutar archivos maliciosos sin aplicar mecanismos de protección de seguridad.
A09: Security Logging & Alerting Failures	Marriott	2018	La empresa tardó mucho tiempo en detectar accesos no autorizados debido a problemas de monitoreo y alertas de seguridad.
A09: Security Logging & Alerting Failures	Uber	2016	Un ataque permaneció oculto porque las actividades sospechosas no fueron detectadas a tiempo por los sistemas de monitoreo.

A10: Mishandling of Exceptional Conditions	Packetbeat	2026	Paquetes manipulados podían provocar fallos y consumo excesivo de recursos, causando caídas del sistema.
A10: Mishandling of Exceptional Conditions	British Airways Entertainment System	2019	El sistema permitía interacción insegura con dispositivos USB, lo que podía provocar fallos y vulnerabilidades como buffer overflow.

Código vulnerable y código seguro

A05: Injection (SQL Injection)

Código vulnerable

```
SELECT * FROM usuarios
WHERE nombre = ' ' + usuario + ' '
```

El sistema concatena directamente los datos ingresados por el usuario, permitiendo ataques de SQL Injection.

Código seguro

```
SELECT * FROM usuarios
WHERE nombre = ?
```

Se utilizan consultas parametrizadas para evitar inyección SQL.

A07: Authentication Failures

Código vulnerable

```
if(password == "123456"){
    acceso = true;
}
```

El sistema utiliza una contraseña débil y escrita directamente en el código.

Código seguro

```
if(validarPassword(passwordIngresada, passwordHash)
    acceso = true;
}
```

Se utilizan contraseñas cifradas y validación segura mediante hashes.

A01: Broken Access Control

Código vulnerable

```
app.get("/admin", function(req, res){
    mostrarPanelAdmin();
});
```

Cualquier usuario puede acceder al panel de administrador porque no se validan permisos.

Código seguro

```
app.get("/admin", function(req, res){

    if(req.user.rol == "admin"){
        mostrarPanelAdmin();
    }else{
        accesoDenegado();
    }

});
```

El sistema verifica que el usuario tenga permisos antes de permitir el acceso al panel de administrador.

Ranking personal de vulnerabilidades más críticas

1. **A01: Broken Access Control**

Personalmente considero que esta es la más peligrosa porque prácticamente le abre la puerta a usuarios no autorizados para entrar a información privada o funciones importantes del sistema. Además, muchos ataques reales ocurren por errores simples de permisos o accesos mal configurados.

2. **A05: Injection**

Siento que Injection sigue siendo una de las vulnerabilidades más críticas porque un atacante puede manipular consultas o comandos fácilmente si el sistema no valida correctamente los datos. Literalmente puede terminar afectando bases de datos completas.

3. **A07: Authentication Failures**

Elegí esta porque hoy en día muchísimas personas siguen usando contraseñas débiles o repitiéndolas en varios sitios. Si el sistema tiene problemas en el login o autenticación, un atacante puede entrar a cuentas ajenas muy fácilmente.

4. **A04: Cryptographic Failures**

Creo que esta vulnerabilidad es muy importante porque muchas aplicaciones manejan información sensible, y si el cifrado es débil o está mal implementado, los datos pueden quedar expuestos. A veces pequeños errores en certificados o claves terminan provocando grandes filtraciones.

5. **A03: Software Supply Chain Failures**

Actualmente casi todas las aplicaciones dependen de librerías externas, APIs o paquetes de terceros. Por eso considero que esta vulnerabilidad ha tomado mucha importancia, porque si una dependencia es comprometida puede afectar a miles de sistemas al mismo tiempo, como pasó con SolarWinds.

Conclusión

Realizar esta investigación sobre el OWASP Top 10 me ayudó muchísimo a entender que la seguridad en las aplicaciones no es algo opcional ni un detalle pequeño, sino una parte muy importante del desarrollo. Honestamente, antes pensaba que muchas vulnerabilidades solo afectaban a empresas enormes o sistemas muy avanzados, pero mientras investigaba me di cuenta de que errores simples pueden provocar problemas bastante graves. Cosas como no validar datos correctamente, usar contraseñas débiles o dejar permisos mal configurados pueden terminar exponiendo información sensible de miles de usuarios.

También siento que conocer el OWASP Top 10 ayuda bastante a crear más conciencia como desarrollador. A veces yo me enfoco demasiado en que el programa funcione, que la interfaz se vea bien o que todo corra rápido, pero yo dejo un poco de lado la seguridad. Y pues realmente de nada sirve una aplicación funcional si cualquier atacante puede aprovechar una vulnerabilidad para acceder al sistema.

Algo que me llamó mucho la atención fue ver que incluso empresas grandes como Uber, LinkedIn, Tesla o SolarWinds han tenido problemas de seguridad importantes. Eso me hizo entender que ningún sistema está completamente protegido y que la seguridad debe tomarse en cuenta desde el inicio del desarrollo y no solamente cuando el proyecto ya está terminado.

En mis próximos proyectos creo que aplicaré este conocimiento siendo más cuidadosa con la validación de datos, el manejo de permisos, las contraseñas y el uso de librerías externas. También considero importante realizar pruebas de seguridad constantemente y mantener los sistemas actualizados, siento que conocer estas vulnerabilidades no solo ayuda a desarrollar mejores aplicaciones, sino también a proteger la información y la confianza de los usuarios.